

review_round1_NOGO

§11.4.252 fail-open batch — §11.4.209 independent review, round 1

Verdict: NO-GO — 0 BLOCKING / 4 IMPORTANT / 6 MINOR Substrate: Fable. Reviewer structurally separate from the author (§11.4.70). 2026-08-25. Loop re-arms per §11.4.134. Nothing from this batch is committed.

Two closure claims are materially false — both proven at runtime

IMPORTANT-1 `plugins/community/jackett.py:266-283`.

`urllib.error.HTTPError` matches the `EARLIER` except `urllib.request.HTTPError` clause, where only `e.code == 302` is handled; every other code falls through with `response = None` and zero output. The new logging branch is **unreachable for HTTP errors**. A real 401 and a real 500 driven through `get_response` both returned `None` with `stderr ''`. The in-code comment claims “a 401 rejected apikey and a 500 ... the reason is now surfaced” — it is not, and the 401 IS the named defect (“a misconfigured apikey looked exactly like an empty search”). §11.4.194(1): two independent branches, one fixed.

IMPORTANT-2 `scripts/extract-jackett-key.py:34`. `except`

`(json.JSONDecodeError, OSError)` does not catch `UnicodeDecodeError` — it subclasses `ValueError`. Feeding a `ServerConfig.json` containing `\xff` makes `extract_key` **propagate**: the script crashes mid-poll and the traceback prints `can't decode byte 0xff in position 19` — a byte OF

THE CREDENTIAL FILE — to stderr. The comment's §11.4.10 rationale cites `UnicodeDecodeError` by name as the reason for class-only logging, so it claims a protection this site does not provide (§11.4.194(2)).

IMPORTANT-3 — the §11.4.10 guard is unvalidated instrumentation (§11.4.115(F)). Reviewer mutation: reinstate the exception MESSAGE into the `auth.py:470` credential log → **all 6 tests still pass**. The sentinel tests plant the sentinel in the ENV VAR while driving `OSError("permission denied") / ConnectionResetError`, whose messages never contain it. So the class-only discipline at `auth.py:470`, `auth.py:534` and `routes.py:1000` (no sentinel test at all) is unguarded against the exact named regression. The author's own `extract-jackett-key` test puts the sentinel IN the payload and would catch it — the right shape existed and was not applied.

IMPORTANT-4 — 3 of 4 streaming handlers have no RED-capable test. The SSE test pins `metadata.status="running"` and `tracker_stats={}`, so :276, :314-326, :412-423 never fire; the assertion is satisfied by :377 alone. Those three would survive their own `fix-revert`.

MINOR

M1 `add-before-yield` permanent drop still exists (observability ≠ repair) — filed as its own item. M2 `extract-jackett-key.py main()` still returns 0 with empty output at poll exhaustion. M3 the three `print(file=sys.stderr)` sites can now raise (`BrokenPipeError`); in `nova2.import_engine` that propagates to :163/:227/:248. The logger sites are immune. M4 `auth.py:556` logs `qbit_url` verbatim — userinfo in the URL would leak. M5 the `nova2` test compiles into a synthetic namespace supplying `sys/importlib`, so it could not catch a missing import in the real module (no live defect — `sys` IS imported at :38). M6 the 74→63 scanner figure could not be independently reproduced; the arithmetic matches the 11 removed sites. REAL-LOW path is `merge_service/jackett_autoconfig.py:283-291`, not `api/`.

Confirmed good (proof basis recorded)

GREEN independently reproduced 10/10 (.venv 3.14.6, pytest 9.1.1) · `fix-revert` mutations re-run in a scratch copy: pre-fix `streaming.py` fails the SSE test, pre-fix `auth.py+search.py` fail exactly 4 — the tests ARE RED-capable · regressions 269 passed (`api_layer`) + 440 passed (`merge_service` subset) · `ruff` + `py_compile` clean on all 9 · **return contracts unchanged in all 9 files, callers enumerated** · the add-

before-yield analysis verified precisely at :317/:356, including that same-batch later results DO re-emit — the author’s “at least one result” wording is accurate · search.py:833 proportionality verified: _run_search re-selects trackers at :895 and its handler at :1047 flips the search to failed, so log-only at the seeding site is right · log-only judgment endorsed for auth, status probe, all four streaming sites, search.py and nova2 — refusing in nova2 would be a §11.4.201(1) false positive, one broken engine killing the roster · 4 REAL-LOW triage confirmed with no mis-triage.

Not analysed (stated, never assumed safe)

Full tests/unit/ suite (same environmental constraint the author hit) · import-time raise surfaces of all 43+ engine modules · the exact scanner behind 74→63.